Summit Ridge Coffee Co. — IT Security Policy

Oct 11, 2026 · @Rebecca

Policy SRC-IT-001, Version 3.0, effective April 1, 2026; next review March 31, 2027. Approved by CEO Dana Whitcomb and owned by IT Manager Samuel Okafor.

Scope and owners

This policy applies to all 142 employees, contractors and vendors who use Summit Ridge systems, devices or networks. Violations can lead to discipline under the Employee Handbook, up to termination.

System	Used for	System owner
Google Workspace	Email, Drive, calendar	Samuel Okafor, IT Manager
Toast POS (38 terminals, 6 cafés)	Café sales, card payments	Samuel Okafor
Shopify	Online store, Summit Club	Olivia Park, Marketing Manager
ADP and BambooHR	Payroll, employee records	Rachel Delgado, HR Director
QuickBooks Online	Accounting	Michael Fenwick, CFO
7shifts	Scheduling	Store Managers
Cropster	Roastery production	Priya Raman, Roastery Director

IT support is provided in-house by Samuel Okafor and IT Specialist Lena Morales, with after-hours coverage from Peak IT Partners, LLC (contract through June 30, 2027).

Accounts, passwords and MFA

Every person gets their own account; shared logins are prohibited except the Toast "Kitchen Display" device account.

Requirement	Standard
Password length	At least 14 characters; passphrases encouraged
Password reuse	Last 10 passwords may not be reused
Password manager	1Password Business, required for all salaried staff
Multi-factor authentication	Required on Google Workspace, ADP, Shopify, QuickBooks and BambooHR; Google Authenticator or a YubiKey, never SMS
Toast POS PIN	6 digits, unique per employee, changed every 180 days
Account lockout	5 failed attempts locks the account for 30 minutes
Screen lock	Laptops lock after 5 minutes idle; POS terminals after 60 seconds

Access changes: Managers request new access through the IT ticket form at least 3 business days before a start date. HR notifies IT of every departure, and all access is removed within 4 hours of an employee's last shift. Admin rights are reviewed quarterly, on the first Monday of January, April, July and October.

Devices, payment cards and Wi-Fi

Company devices: All 31 company laptops run CrowdStrike Falcon and full-disk encryption (BitLocker or FileVault). Operating system updates are installed within 14 days of release, or within 72 hours for critical patches. USB storage drives are blocked on POS and office computers.

Personal phones: Staff may check 7shifts and Gmail on personal phones only if they enroll in Google endpoint management, which requires a 6-digit screen lock. IT can remotely wipe company data, but not personal data, if a phone is lost.

Payment cards (PCI DSS 4.0):

- Card numbers are never written down, photographed, emailed or entered anywhere except a Toast terminal or Shopify checkout.
- Openers inspect each card reader for tampering before 6:00 AM and initial the daily checklist.

- Phone orders paid by card are not accepted.
- Peak IT Partners runs quarterly external vulnerability scans; the annual SAQ is due each March 31.

Wi-Fi: Each café runs three separate networks. "SRC-POS" carries payment terminals only, "SRC-Staff" is for company devices, and "SummitRidge-Guest" is isolated, with a 2-hour session limit. The staff network password rotates on the 1st of each quarter. Personal devices may never join SRC-POS.

Data handling, email and acceptable use

Data class	Examples	Rules
Restricted	Card data, Social Security numbers, bank details, medical leave records	Stored only in Toast, ADP or BambooHR; never in email, Drive or spreadsheets
Confidential	Sales reports, wage rates, wholesale pricing, supplier contracts	Shared only inside Google Workspace; external sharing needs manager approval
Internal	Schedules, recipes, training guides	Staff only; not posted publicly
Public	Menu, published prices, blog posts	No restrictions

- **Email:** External messages are tagged [EXTERNAL]. Wire transfers, gift card purchases or changes to vendor bank details requested by email must be confirmed by phone with a known number. Michael Fenwick approves any payment change over $2,500.
- **AI tools:** Only the company Google Workspace Gemini license may be used with Confidential data. Restricted data is never entered into any AI tool.
- **Personal use:** Brief personal use of company laptops is allowed. Gambling, crypto mining, torrenting and adult content are prohibited.
- **Retention:** Customer records are kept 3 years, employee files 7 years after separation, and CCTV footage 30 days unless tied to an incident.
- **Disposal:** Paper with Confidential or Restricted data goes in the locked Shred-it bins at each site, emptied every other Tuesday.

Incident reporting, training and enforcement

Report any suspected incident within 1 hour, including a phishing click, a lost device, a tampered card reader or an unexpected password reset. Call the security line at (303) 555-0210 (24/7) and email security@summitridgecoffee.com. Do not try to investigate on your own.

1. **Contain:** IT disables affected accounts or takes devices offline within 30 minutes of the report.
2. **Assess:** Samuel Okafor rates the severity as Low, Medium, High or Critical within 4 hours.
3. **Escalate:** High and Critical incidents go to Dana Whitcomb and Michael Fenwick right away. Card data incidents also go to the Toast and Shopify security teams within 24 hours.
4. **Notify:** If personal data was exposed, affected people and the Colorado Attorney General are notified within 30 days, as Colorado law (C.R.S. 6-1-716) requires.
5. **Review:** A written post-incident review is completed within 10 business days.

Training: All staff complete the 25-minute KnowBe4 security course within 7 days of hire and again every January. Monthly simulated phishing emails go to all salaried staff. Anyone who fails two simulations in 6 months repeats the course within 14 days.

Enforcement: Willful violations, such as sharing a password or storing card numbers, lead to a final written warning on a first offense and termination on a second. Questions about this policy go to Samuel Okafor at helpdesk@summitridgecoffee.com, ext. 210.